

# **Análisis Estratégico y Taxonomía Avanzada del Ecosistema de Inteligencia Artificial en Ciberseguridad: Arquitecturas, Herramientas y Paradigmas Emergentes**

El ecosistema de la ciberseguridad ha experimentado una reestructuración tectónica impulsada por la adopción masiva de la Inteligencia Artificial Generativa (GenAI) y los Modelos de Lenguaje Grande (LLMs). La proliferación de recursos descentralizados ha generado un vasto panorama de herramientas que requieren una clasificación rigurosa para su adopción empresarial. Repositorios fundamentales como Awesome-AI-Cyber (ElNiak), AI-for-Cybersecurity (cybershujin), Awesome-GPT-Agents (frOgger) y Awesome GenAI CyberHub (Ashfaaq98) han servido como los nodos cartográficos primarios desde los cuales la industria ha comenzado a mapear estas capacidades.

El presente informe proporciona una disección exhaustiva y detallada de este ecosistema tecnológico hasta el año 2026. A través del análisis de estos repositorios y de decenas de marcos de trabajo complementarios, el documento estructura el campo en dos macro-disciplinas interconectadas: la "Inteligencia Artificial para Ciberseguridad" (el uso de IA para proteger infraestructuras tradicionales o emular atacantes) y la "Seguridad para la Inteligencia Artificial" (la protección de los propios modelos LLM, sus tuberías de datos y agentes autónomos frente a ataques adversarios).<sup>1</sup>

## **1. Fundamentos Teóricos y la Evolución del Ecosistema**

La integración de la inteligencia artificial en la ciberseguridad no es un fenómeno reciente, pero su naturaleza ha mutado. Históricamente, las aplicaciones de IA en ciberseguridad se han categorizado utilizando el modelo PPDR (Predicción, Prevención, Detección y Respuesta) de Gartner.<sup>3</sup> Las primeras iteraciones de este modelo dependían en gran medida de técnicas de aprendizaje automático (Machine Learning) clásico y aprendizaje profundo (Deep Learning) orientadas a la detección de anomalías y la clasificación.<sup>3</sup>

### **1.1 El Paradigma del Machine Learning Clásico**

Antes de la llegada de los agentes autónomos, la industria dependía de arquitecturas analíticas específicas para cada capa de la red y del endpoint. Las herramientas recopiladas en repositorios históricos y actualizados revelan un uso intensivo de algoritmos tradicionales para resolver problemas deterministas<sup>3</sup>:

- **Protección de Red (Network Traffic Analytics - NTA):** Los Sistemas de Detección y Prevención de Intrusos (IDS/IPS) utilizan algoritmos de regresión para predecir los parámetros de los paquetes de red y clasificación para identificar anomalías como escaneos de puertos o suplantación de identidad (spoofing).<sup>4</sup> El uso de Redes Neuronales Recurrentes (RNNs) ha sido fundamental para reducir los falsos positivos al modelar el tráfico de red como una serie temporal continua.<sup>4</sup>
- **Protección de Endpoints:** La defensa contra malware, spyware y ransomware en estaciones de trabajo y dispositivos IoT se ha beneficiado de técnicas de regresión para predecir la próxima llamada al sistema (system call) de un proceso ejecutable, y algoritmos de agrupación (clustering) para la detección de malware en pasarelas de correo electrónico seguras.<sup>3</sup>
- **Análisis de Comportamiento del Usuario y la Entidad (UEBA):** A diferencia de la detección de malware basada en firmas, la analítica de comportamiento utiliza aprendizaje no supervisado. Mediante técnicas de agrupación y clasificación de grupos de pares (peer-group analysis), los sistemas pueden identificar valores atípicos (outliers) en las acciones de los usuarios, como inicios de sesión anómalos o exfiltración de datos lenta.<sup>3</sup>
- **Comportamiento de Procesos y Antifraude:** La detección de fraudes en transacciones financieras o el monitoreo de sistemas de control industrial utilizan redes neuronales profundas para distinguir registros (logs) limpios de aquellos maliciosos, prediciendo acciones atípicas de los procesos comerciales.<sup>3</sup>

## 1.2 La Era de los Enjambres (Swarm Architectures) y los Agentes LLM

El ecosistema ha transitado de estos modelos predictivos estáticos hacia sistemas de "agentes" basados en LLMs. Entre 2024 y 2026, la industria observó cómo los asistentes conversacionales interactivos evolucionaron hacia arquitecturas de enjambre (swarm architectures).<sup>5</sup> En este nuevo paradigma, los planificadores, ejecutores y evaluadores operan de forma orquestada y autónoma.<sup>5</sup>

El diseño de agentes jerárquicos divide los flujos de trabajo complejos en sub-agentes especializados. Por ejemplo, un agente se dedica exclusivamente al reconocimiento pasivo, mientras que otro sintetiza exploits y un tercero audita el éxito de la inyección. Esta especialización ha demostrado una mejora drástica en la explotación de vulnerabilidades en comparación con los agentes monolíticos que intentan resolver un problema de extremo a extremo en un solo hilo de contexto.<sup>5</sup>

## 1.3 La Brecha entre el Laboratorio y el Entorno Real (Lab-to-Real Gap)

A pesar del entusiasmo en torno a las arquitecturas de agentes, los análisis empíricos revelan un fenómeno crítico: la brecha entre el laboratorio y la realidad. Modelos fundacionales masivos como GPT-4 son capaces de explotar teóricamente un alto porcentaje de las vulnerabilidades y exposiciones comunes (CVE) de un solo día cuando se les proporciona una descripción estructurada del fallo.<sup>5</sup> Sin embargo, en entornos de producción simulados o

plataformas de desafío avanzadas (como HackTheBox o los entornos del banco de pruebas CVE-Bench), la tasa de éxito de estos mismos agentes cae estrepitosamente, y a menudo roza el 0% en objetivos severamente endurecidos.<sup>5</sup>

Esta degradación del rendimiento se debe a deficiencias de ingeniería, como la falta de herramientas integradas en el entorno del agente, y a la incapacidad del LLM para mantener el razonamiento a largo plazo (long-horizon reasoning) frente a señales ambientales ambiguas o ruido en las respuestas del servidor objetivo.<sup>6</sup> Por lo tanto, el diseño contemporáneo exige sistemas que no solo alberguen modelos inteligentes, sino que implementen un patrón estructurado que mantenga el estado de forma persistente y separe las hipótesis de la evidencia comprobada.<sup>6</sup>

## 2. Pruebas de Penetración Autónomas y Seguridad Ofensiva (Offensive AI)

El dominio de la seguridad ofensiva ha catalizado el desarrollo de las arquitecturas de IA más sofisticadas. La necesidad de validación continua frente a ciclos de desarrollo ágiles ha hecho que las auditorías manuales anuales resulten insuficientes y económicamente ineficientes.<sup>7</sup> Para 2026, el mercado cuenta con decenas de proyectos de agentes de pentesting de código abierto y plataformas comerciales emergentes.<sup>5</sup>

### 2.1 Marcos de Trabajo Integrales para Pruebas de Penetración

El desarrollo de sistemas de Red Teaming autónomo ha fragmentado las herramientas en utilidades orientadas a la investigación y plataformas listas para la empresa.

- **PentestGPT (Versión 1.0):** Este proyecto, uno de los pioneros en la orquestación de LLMs para pentesting, ha trascendido su naturaleza original de asistente conversacional para convertirse en un agente autónomo integral. La versión 1.0 consolidó un diseño "Docker-First", aislando el entorno de ejecución para garantizar la reproducibilidad y la seguridad del host, al tiempo que integraba las herramientas de seguridad necesarias preinstaladas.<sup>6</sup> Una característica definitoria de su arquitectura es la persistencia de la sesión, lo que permite pausar y reanudar campañas de pruebas prolongadas.<sup>8</sup> Evaluaciones independientes sobre suites de validación demostraron que PentestGPT alcanza tasas de éxito de más del 86%, completando la validación de vulnerabilidades de manera altamente coste-eficiente.<sup>8</sup>
- **HackingBuddyGPT:** Gestado en el ámbito académico (TU Wien) y respaldado por el acelerador de GitHub, este marco permite a los investigadores de seguridad desarrollar agentes de hacking autónomos en apenas 50 líneas de código.<sup>2</sup> A diferencia de los enfoques puramente teóricos, HackingBuddyGPT ejecuta comandos en entornos reales, ofreciendo modalidades de conexión SSH hacia objetivos remotos y ejecución de comandos en shells locales mediante sesiones tmux.<sup>2</sup> El sistema opera mediante casos de uso configurables, siendo los más maduros la escalada de privilegios en Linux y la

evaluación de aplicaciones web y APIs REST.<sup>2</sup> Su arquitectura iterativa evalúa la salida del comando anterior e inyecta esa información en el siguiente prompt, utilizando técnicas de Cadena de Pensamiento (Chain of Thought - CoT) y Generación Aumentada por Recuperación (RAG) consultando bases de datos vectoriales para identificar la técnica de escalada óptima.<sup>10</sup>

- **HexStrike AI:** Un revolucionario marco de trabajo de seguridad ofensiva que opera bajo una arquitectura multi-agente e integra de forma nativa más de 150 herramientas profesionales de ciberseguridad (incluyendo Nmap, FFuf, SQLMap, Trivy y herramientas de ingeniería inversa). HexStrike AI se apoya en el protocolo MCP (Model Context Protocol), actuando como un servidor FastMCP que sirve de enlace entre modelos de lenguaje (como Claude, GPT o Copilot) y las funciones tácticas del entorno. Su capa de abstracción tiene la capacidad de traducir comandos ambiguos de intención (como "explotar NetScaler") en una secuencia metódica de herramientas y ejecuciones. De este modo, dota a los agentes de IA de una inteligencia de vulnerabilidades en tiempo real para descubrimiento automatizado, pruebas en aplicaciones web complejas (con inyección de JavaScript y navegadores *headless*) y resolución de retos. De manera alarmante, actores de amenazas ya han reportado en foros que HexStrike AI es capaz de reducir el tiempo de explotación de un día cero (Zero-Day) de semanas a menos de 10 minutos, como se evidenció recientemente en ataques *in the wild* contra vulnerabilidades de Citrix NetScaler.
- **XBOW y ARTEMIS (Plataformas Comerciales):** En el extremo superior de la automatización empresarial, plataformas como XBOW han superado los umbrales de rendimiento humano. En evaluaciones notables, el agente autónomo de XBOW alcanzó el primer puesto en la tabla de clasificación global de HackerOne, superando a miles de investigadores de seguridad humanos mediante la automatización a velocidad de máquina y la validación matemática de exploits sin falsos positivos. Del mismo modo, herramientas como ARTEMIS han demostrado una alta capacidad para la enumeración sistemática y el descubrimiento de fallos de lógica a gran escala operando a una fracción del coste por hora de los pentesters manuales.

## 2.2 Agentes Especializados y Micro-Tareas (Custom GPTs)

El repositorio *Awesome-GPT-Agents* ilustra cómo la comunidad ha fragmentado la complejidad de la ciberseguridad en agentes especializados alojados en interfaces de chat estándar, los cuales sirven como asistentes tácticos para ingenieros de seguridad <sup>11</sup>:

| Categoría Operativa | Herramienta/Agente Destacado | Función Principal y Capacidades |
|---------------------|------------------------------|---------------------------------|
|                     |                              |                                 |

|                                           |                                                                     |                                                                                                                                                                                                           |
|-------------------------------------------|---------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Ofensiva y Pentesting</b>              | GP(en)T(ester),<br>HackTricksGPT, h4ckGPT                           | Proporcionan orientación paso a paso para pruebas de penetración y acceso inmediato a bases de conocimiento profesionales consolidadas.                                                                   |
| <b>Análisis de Malware e Inteligencia</b> | Threat Intel Bot, IOC Analyzer, Malware Rule Master, MagicUnprotect | Procesan telemetría y memorias para generar resúmenes de Indicadores de Compromiso (IoCs) y redactar reglas YARA para la detección estática. Interacción con bases de datos de técnicas de evasión.       |
| <b>Investigación de Vulnerabilidades</b>  | CyberGPT, VulnPrioritizer                                           | Recuperan detalles de CVEs de bases de datos actualizadas y aplican modelos de puntuación como EPSS para proporcionar resúmenes priorizados que guían los parches de remediación.                         |
| <b>Modelado de Amenazas y Diseño</b>      | Threat Modelling, Threat Model Buddy                                | Utilizan metodologías estructuradas (como PASTA) para identificar vectores de ataque durante la fase de diseño arquitectónico y transicionar arquitecturas en la nube hacia modelos formales de amenazas. |
| <b>Asesoramiento y Marcos</b>             | MITREGPT, CISO AI, CMMC                                             | Asignan entradas tácticas a las matrices de MITRE ATT&CK, y                                                                                                                                               |

|                                                 |                                   |                                                                                                                                                                                        |
|-------------------------------------------------|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                 | GPT                               | proporcionan orientación ejecutiva y de cumplimiento para diversas certificaciones.                                                                                                    |
| <b>Inteligencia de Fuentes Abiertas (OSINT)</b> | Cylect.io, AlphaHoundAI, GetPaths | Buscan inteligencia en la web profunda, interactúan con tecnologías de grafos (BloodHound) para analizar Directorio Activo, y extraen URLs de aplicaciones para pruebas de superficie. |

## 2.3 Evolución de Plataformas Tradicionales: El Ecosistema de Burp Suite y Burp AI

Lejos de quedar obsoletas por los agentes 100% autónomos, las plataformas de pruebas de penetración web estándar de la industria (como Burp Suite de PortSwigger) han internalizado la IA Generativa mediante una filosofía de "Humano en el Bucle" (Human-In-The-Loop). A lo largo de las versiones de 2025 y 2026, PortSwigger introdujo **Burp AI**, un conjunto de características diseñadas para aumentar al investigador sin tomar el control total de la auditoría.

Las integraciones clave del ecosistema Burp Suite potenciadas por IA incluyen:

- **Explore Issue:** Una capacidad de seguimiento automatizado (Automated follow-up) que actúa como un pentester junior. Toma las vulnerabilidades identificadas estáticamente por el Burp Scanner e investiga proactivamente la aplicación, intentando crear exploits de Prueba de Concepto (PoC) y vectores de ataque adicionales, proporcionando finalmente un resumen ejecutivo de impacto.
- **Explainer (Integración en Repeater):** Permite al analista sombrear fragmentos de tráfico HTTP oscuros, código JavaScript ofuscado o encabezados desconocidos directamente en la pestaña "Repeater" y obtener una explicación generada por IA sobre su impacto en la seguridad. Esto elimina drásticamente la fricción del cambio de contexto y las búsquedas externas en la web.
- **Reducción de Falsos Positivos en Tiempo Real:** Burp AI ha modificado la lógica heurística del escáner tradicional para filtrar falsos positivos. Específicamente, ha mejorado masivamente en la evaluación de vulnerabilidades de Control de Acceso Roto (Broken Access Control) y ha refinado la detección de inyecciones SQL basadas en tiempo, logrando distinguir si un retraso (delay) es causado por un exploit exitoso o simplemente por la limitación de un Firewall de Aplicaciones Web (WAF).
- **Secuencias de Inicio de Sesión Generadas por IA (Recorded Logins):** Automatiza una

de las tareas más tediosas del escaneo dinámico: la configuración del estado de autenticación. Burp AI genera automáticamente flujos de inicio de sesión de múltiples pasos, permitiendo escaneos DAST profundos en plataformas altamente seguras o con flujos SSO complicados.

- **La API de Montoya y la Economía de Extensiones:** A nivel de desarrollador, la API de Montoya de Burp ha sido actualizada para dar soporte nativo a llamadas de modelos de IA. En lugar de que cada pentester gestione sus propias claves de OpenAI o Anthropic en extensiones dispares (como *BurpGPT*), la infraestructura de PortSwigger permite crear extensiones que gastan un saldo centralizado de "Créditos de IA" operando dentro del límite de confianza de la herramienta, asegurando que los datos sensibles del cliente no se filtren a modelos públicos. Extensiones de la comunidad muy populares como *Hackvector* ya están aprovechando este backend para auto-generar etiquetas de ofuscación personalizadas y codificación/decodificación de payloads mediante IA.

### 3. Seguridad para Modelos de Lenguaje (AI Red Teaming y Escáneres de Vulnerabilidad)

A medida que las Organizaciones despliegan Aplicaciones Impulsadas por LLMs (LPAs), la superficie de ataque ha metamorfoseado. Las vulnerabilidades tradicionales conviven ahora con amenazas estocásticas: inyecciones de prompts (prompt injection), evasión de restricciones (jailbreaking), fuga de datos de entrenamiento y alucinaciones explotables.<sup>12</sup> Para mitigar estos riesgos, ha surgido una nueva clase de infraestructura orientada al "Red Teaming" de los propios modelos de inteligencia artificial.<sup>2</sup>

#### 3.1 Infraestructuras de Escaneo Dinámico (Dynamic Vulnerability Scanners)

Las pruebas manuales de penetración contra LLMs son insuficientes debido a la naturaleza probabilística de sus respuestas. Para evaluar un modelo con rigor, se requieren escáneres que mecanicen millones de permutaciones semánticas.<sup>2</sup>

- **PyRIT (Python Risk Identification Tool):** Creado y mantenido por el AI Red Team de Microsoft (ahora integrado en Azure AI Foundry), PyRIT es un marco de automatización fundamental para campañas adversarias.<sup>12</sup> Su diseño aborda la naturaleza probabilística de los LLMs mediante un enfoque modular que combina decenas de conjuntos de datos de investigación y más de 70 conversores de prompts (que traducen ataques a Base64, ROT13, Leetspeak, o aplican confusión Unicode y refraseo mediante LLMs).<sup>14</sup> En lugar de evaluar respuestas con aserciones binarias simples, PyRIT emplea un motor de puntuación (scoring engine) que utiliza clasificadores locales y "LLMs como jueces" para evaluar la toxicidad o fuga de datos a gran escala.<sup>14</sup> A través de su implementación en servidores MCP, PyRIT puede ser orquestado dinámicamente por agentes que actúan como "directores de pruebas", ejecutando ataques de escalada multi-turno contra endpoints cerrados o modelos locales.<sup>16</sup>

- **garak (Generative AI Red-teaming & Assessment Kit):** Respaldado por NVIDIA y adoptado ampliamente en la industria, garak opera bajo la misma filosofía heurística que herramientas clásicas como Nmap o Metasploit, pero orientada a los LLMs.<sup>18</sup> Somete al modelo objetivo a un bombardeo exhaustivo utilizando una biblioteca de sondas (probes) especializadas. Entre sus sondas destacan *DAN* (Do Anything Now) diseñada para eludir políticas éticas y forzar respuestas inapropiadas, e inyecciones de codificación (*Encoding*) que intentan burlar los filtros tradicionales de entrada ofuscando intenciones maliciosas.<sup>20</sup> El marco puede evaluar modelos alojados en Hugging Face, OpenAI, Replicate o conexiones a través de cualquier punto final REST o formato GGUF.<sup>21</sup>
- **promptfoo:** Mientras que herramientas como PyRIT se inclinan hacia la investigación y la orquestación programática pesada, promptfoo prioriza la experiencia del desarrollador y la integración en el ciclo de Integración y Despliegue Continuos (CI/CD).<sup>12</sup> Adquirida recientemente por OpenAI (tras integrarse en un gran porcentaje de las empresas Fortune 500), esta plataforma realiza el red-teaming adaptativo impulsando a agentes de IA a generar ataques específicos basados en el contexto en lugar de depender de listas de prompts estáticas.<sup>15</sup> Es excepcionalmente valiosa para las organizaciones empresariales debido a su capacidad de mapeo de cumplimiento normativo (Compliance Mapping): cada hallazgo de vulnerabilidad se vincula automáticamente a taxonomías reconocidas como el OWASP Top 10 para Aplicaciones LLM, NIST, MITRE ATLAS y las regulaciones de la Ley de IA de la Unión Europea (EU AI Act).<sup>15</sup>

### 3.2 Marcos de Cumplimiento, RAG y Ecosistemas Integrales

Para aplicaciones que van más allá del simple chat y entran en la Generación Aumentada por Recuperación (RAG) o la ejecución de infraestructuras complejas, el conjunto de herramientas de Red Teaming debe ampliarse.

- **Giskard:** Esta plataforma de pruebas se especializa en la evaluación profunda de sistemas RAG y en el cumplimiento estricto de normativas como la EU AI Act.<sup>12</sup> A diferencia de los escáneres puramente basados en el prompt, Giskard evalúa la *lógica* y el *conocimiento* subyacente. Ingiere documentos de políticas internas y genera automáticamente preguntas dinámicas para realizar pruebas de regresión. Esto asegura que no ocurran "fugas lógicas". Su mecanismo de generación de "conjuntos de datos dorados" (Golden Datasets) proporciona un marco de verdad fundamental (ground truth) que alerta a los desarrolladores si una actualización del LLM degrada la precisión.<sup>23</sup>
- **PurpleLlama (Meta):** Concebido como un proyecto paraguas, PurpleLlama centraliza herramientas para promover la IA generativa responsable y segura bajo licencias permisivas.<sup>12</sup> Incluye la suite *CyberSecEval*, orientada a cuantificar estadísticamente el riesgo de un LLM sugiriendo código inseguro o asistiendo en ciberataques.<sup>24</sup> El ecosistema distribuye los modelos *Llama Guard 3*, los cuales son LLMs ajustados específicamente para actuar como guardianes taxonómicos. Estos modelos están entrenados para detectar la intención de cometer crímenes cibernéticos y evitar la generación de código malicioso estructurado.<sup>24</sup>



- **Strix y CAI:** Cuando se combinan con herramientas como promptfoo y Giskard, plataformas como Strix auditan la envoltura de la aplicación web y las API buscando vulnerabilidades de Interfaz de Programación de Aplicaciones, mientras que CAI orquesta ataques de infraestructura para probar si el contenedor que aloja al agente de IA puede ser violado para pivotar hacia redes internas.

## 4. Defensa Activa, Guardarraíles (Guardrails) y Aislamiento en Tiempo de Ejecución

La prevención en tiempo real constituye la barrera definitiva en las arquitecturas GenAI. La industria ha estructurado esta defensa en múltiples capas, asegurando tanto la validación de los datos que entran y salen del modelo como el contenedor operativo donde residen los agentes.<sup>13</sup>

### 4.1 Marcos de Validación y Filtrado (I/O Guardrails)

Las herramientas de validación semántica actúan como cortafuegos inteligentes situados perimetralmente al LLM.

- **LLM Guard (Protect AI):** Se posiciona como un kit de herramientas de seguridad integral diseñado para interacciones con LLMs.<sup>13</sup> Antes de procesar el texto, LLM Guard aplica escáneres de entrada y salida que detectan inyecciones de prompts ocultas, sanitizan el texto eliminando lenguaje dañino o restrictivo, y bloquean la fuga de datos sensibles (Data Leakage) como Información de Identificación Personal (PII).<sup>27</sup> Al implementar validación estricta y limitación de tasa (Rate Limiting), neutraliza la excesiva demanda computacional que podría desencadenar ataques de denegación de servicio a nivel semántico.<sup>30</sup>
- **Rebuff:** Un detector de inyección de prompts especializado que emplea un mecanismo de auto-endurecimiento (self-hardening) para asegurar aplicaciones GenAI.<sup>13</sup> Rebuff emplea una estrategia multifactorial: primero, compara las solicitudes contra una base de datos vectorial de firmas de ataques conocidos; segundo, evalúa la entrada a través de heurísticas y modelos analíticos rápidos.<sup>31</sup> Su innovación más destacada es el uso de "palabras canario" (canary words) inyectadas subrepticamente para alertar sobre la subversión de las políticas (system prompts) si estas llegan a reflejarse en la salida.<sup>31</sup>
- **Otras plataformas del Ecosistema Protect AI:** Integrado con el paradigma de código abierto, herramientas como modelscan inspeccionan la serialización de modelos para proteger contra ataques en la cadena de suministro, nbdefense securiza los entornos de cuadernos Jupyter, y vulnhuntr aprovecha los LLMs para realizar descubrimientos de vulnerabilidades zero-shot sobre repositorios masivos de código.<sup>3</sup>

### 4.2 Seguridad en Tiempo de Ejecución para Agentes (Agent Runtime Security)

La delegación de autonomía a agentes capaces de invocar funciones, modificar el sistema de archivos y acceder a bases de datos demanda un control perimetral físico y virtual. Los Marcos de Inferencia Local (Local Inference Frameworks - LIFs) han demostrado vulnerabilidades sistémicas vinculadas a la propia arquitectura LLM, como el abuso de la caché de prefijos para agotar recursos, la decodificación guiada que provoca desbordamientos, y operaciones de deserialización inseguras.<sup>33</sup> Para mitigar el daño potencial:

- **OpenShell y OpenSandbox:** Proporcionan entornos de ejecución privados (sandboxing) diseñados explícitamente para agentes de IA autónomos. Utilizando infraestructuras como gVisor, contenedores Kata o microVMs de Firecracker, estas herramientas operan bajo políticas YAML declarativas estrictas que impiden que el agente acceda a archivos no autorizados del sistema anfitrión y restrinjan la exfiltración de datos no controlada.<sup>12</sup>
- **Aegis (Antropos):** Funciona como una plataforma de Detección y Respuesta de Endpoints (EDR) de código abierto para ecosistemas de agentes. A diferencia de las soluciones corporativas tradicionales, Aegis monitorea en tiempo real las llamadas a procesos, sistemas de archivos y telemetría de red manteniéndolo todo localmente, sin enviar telemetría a la nube.<sup>12</sup>
- **Microsoft Agent Governance Toolkit:** Un conjunto de herramientas de ingeniería de confiabilidad que implementa el principio de privilegio mínimo, garantizando identidad de confianza cero (zero-trust identity) para las comunicaciones inter-agente y forzando el cumplimiento normativo sobre el OWASP Agent Top 10.<sup>12</sup>
- **Controles de Nivel de Protocolo y Proxies (pipelock, skill-scanner):** Proxies como pipelock actúan como un arnés de seguridad para el tráfico de salida de la IA. Analizan los escaneos de Prevención de Pérdida de Datos (DLP) y auditan las respuestas generadas por los servidores MCP, neutralizando ataques de Falsificación de Solicitudes del Lado del Servidor (SSRF) dirigidos a manipular las herramientas del agente.<sup>12</sup>

## 5. Inteligencia de Amenazas (CTI), SOC y Análisis Forense Digital

En las arquitecturas de red defensivas, la capacidad de procesar terabytes de telemetría de seguridad supera las limitaciones cognitivas humanas. Los repositorios de la comunidad delinean una subdisciplina madura dedicada a la analítica operacional del Centro de Operaciones de Seguridad (SOC) y la Inteligencia de Amenazas (CTI) mediante la asimilación del lenguaje natural.

### 5.1 Modelos Fundacionales Específicos para Ciberseguridad

Para procesar eficazmente artefactos como binarios ofuscados, paquetes PCAP y registros del sistema, la comunidad ha entrenado modelos de lenguaje sobre corpus hiper-técnicos<sup>1</sup>:

- **SecureBERT:** Un modelo codificador basado en la arquitectura BERT, preentrenado masivamente sobre un inmenso corpus de literatura técnica, informes de incidentes y

avisos de seguridad. Demuestra una precisión inigualable en el Reconocimiento de Entidades Nombradas (NER) para la clasificación semántica en la ingesta de fuentes de inteligencia (threat feeds).<sup>1</sup>

- **Sec-Gemini 1.0 (Google):** Representa un modelo de frontera experimental calibrado para razonar profundamente sobre eventos de red anómalos y compilar relaciones de ataque sofisticadas en ecosistemas nubosos.<sup>1</sup>
- **Foundation Sec 8B y Lily Cybersecurity 7B v0.2:** Modelos de peso abierto y ajustados al dominio de la ciberseguridad. Foundation Sec 8B extiende las capacidades de Llama-3.1 hacia la asimilación de texto cibernético puro, mientras que Lily Cybersecurity (basado en Mistral) ha sido entrenado sobre pares de datos artesanales de red teaming y evaluación defensiva, logrando un equilibrio óptimo entre eficiencia computacional en el perímetro y razonamiento técnico.<sup>1</sup>

## 5.2 Servidores MCP, Bot de Inteligencia y Análisis de Malware

El Model Context Protocol (MCP) ha revolucionado la conectividad en herramientas del SOC. Los servidores MCP permiten a los agentes de seguridad conectarse instantáneamente a repositorios de inteligencia de amenazas, permitiendo orquestaciones complejas.<sup>1</sup>

- **Servidores MCP para Operaciones de Seguridad:** Existen servidores de código abierto especializados que habilitan la interacción directa de los agentes LLM con ecosistemas críticos como **VirusTotal** (para validación de hashes y análisis en entornos controlados), **OpenCTI** (plataforma de gestión de inteligencia), **Alien Vault** y servidores de **Reconocimiento Externo** automatizado.<sup>1</sup> Estas integraciones permiten a un analista delegar flujos de investigación completos a un asistente de IA sin depender de procesos de copiar y pegar en diferentes ventanas de navegador.
- **Automatización de Triage:** Integraciones en el repositorio *Awesome-GPT-Agents* presentan herramientas como **IOC Analyzer**, que procesan flujos de información dispares para extraer resúmenes concisos de Indicadores de Compromiso. Herramientas auxiliares como **Malware Rule Master** son capaces de ingerir el comportamiento de un binario y sintetizar automáticamente reglas YARA para que el SOC pueda desplegar defensas estáticas de manera reactiva inmediata.<sup>11</sup>
- **OSINT Orientado por IA:** El reconocimiento de código abierto se ha escalado drásticamente mediante agentes. Tecnologías como **AlphaHoundAI** actúan como expertos en BloodHound CE y Cypher, permitiendo consultas semánticas complejas sobre topologías de Directorio Activo comprometidas. Herramientas como **GetPaths** analizan mecánicamente archivos de aplicación (tráfico HTTP y JavaScript minificado) para generar listas de URLs de superficie para análisis de vulnerabilidad posterior.<sup>11</sup>

## 6. Seguridad de Código (AppSec) e Integración DevSecOps

Garantizar que el código fuente generado por IA o desarrollado por equipos de ingeniería

interna esté libre de vulnerabilidades es un desafío preeminente. Las soluciones se centran tanto en herramientas de Análisis Estático (SAST) y Dinámico (DAST) tradicionales aumentadas por IA, como en la evaluación del código derivado directamente de asistentes generativos.

- **GitHub Advanced Security (GHAS) y Copilot:** Alojado en los cimientos del ecosistema de desarrollo, GitHub incorpora inteligencia artificial generativa a lo largo de las canalizaciones de seguridad. GHAS despliega funciones de escaneo de código (SAST profundo), escaneo de secretos para prevenir exfiltración de claves de API en confirmaciones de código (commits) y gestión algorítmica de vulnerabilidades en la cadena de suministro, unificando la postura de seguridad sin fricciones para el desarrollador.
- **Aikido Security:** Operando como una plataforma DevSecOps de primer nivel sobre el ecosistema GitHub, Aikido unifica escáneres múltiples (código, dependencias de software, secretos, Infraestructura como Código) en un panel de control consolidado. Su diferenciador clave radica en el triaje inteligente; en lugar de paralizar los ciclos de compilación con falsos positivos, los motores impulsados por IA determinan qué vulnerabilidades son contextualmente "alcanzables" y explotables en tiempo de ejecución. Al ofrecer correcciones automáticas (auto-fixes) basadas en inteligencia artificial directamente sobre las solicitudes de extracción (Pull Requests), Aikido transforma la identificación estática de riesgos en un flujo de remediación continuo y sin fricción.<sup>20</sup>
- **CAI (Alias Robotics):** Plataformas avanzadas para la automatización de la ciberseguridad mediante IA que operan en la capa de la infraestructura, evaluando los cimientos donde residen las aplicaciones complejas.

## 7. Datasets, Benchmarks y Evaluación Métrica

El cuello de botella analítico más severo en la ciberseguridad basada en GenAI radica en la carencia de métricas estandarizadas, imparciales y realistas para evaluar modelos y herramientas.<sup>2</sup> Un modelo no medido es un modelo no confiable.

### 7.1 Conjuntos de Datos de Entrenamiento (Datasets)

Históricamente, los algoritmos de detección de intrusiones se entrenaban con corpus de red obsoletos y sesgados como KDD Cup 99 o NSL-KDD, los cuales fueron fuertemente criticados por no reflejar el nivel de sofisticación del tráfico de red contemporáneo.<sup>36</sup> Progresivamente, los investigadores migraron a repositorios más sofisticados como el Kyoto 2006+ Benchmark Dataset, que incluye características estadísticas extraídas mediante análisis forense, o el HIKARI-2021 Dataset.<sup>36</sup>

Para el entorno LLM actual, la crisis de los corpus reside en la escasez de flujos de trabajo de ciberseguridad razonados por expertos. Colecciones recientes como **Primus-Reasoning** y **Primus-Instruct** están llenando este vacío, permitiendo el entrenamiento e instilación de modelos comerciales y de código abierto para que comprendan las secuencias tácticas

complejas requeridas en la toma de decisiones ofensivas.<sup>2</sup> Adicionalmente, el **AI AppSec Index** suministra conjuntos de datos curados que detallan el mapeo de cumplimiento con la Ley de Resiliencia Cibernética (EU CRA) y métricas de regresión sobre decenas de CVEs documentadas en código escrito exclusivamente por IA.<sup>2</sup>

## 7.2 Bancos de Pruebas Cibernéticos (Benchmarks)

Para resolver la Brecha Laboratorio-Realidad y asegurar sistemas confiables, han proliferado marcos de evaluación multicapa que cuantifican las capacidades tanto ofensivas como defensivas <sup>1</sup>:

| Marco de Evaluación (Benchmark) | Objetivo Analítico Principal          | Metodología y Aplicación                                                                                                                                                                                    |
|---------------------------------|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CyberBench / Cybench            | Evaluación multi-tarea general        | Validar la precisión técnica y los riesgos intrínsecos del conocimiento de los LLMs en dominios amplios de ciberseguridad.                                                                                  |
| CVE-Bench / AutoPatchBench      | Tasa de explotación y reparación real | Mide la viabilidad pragmática de los agentes de IA para explotar vulnerabilidades de aplicaciones web en condiciones del mundo real; y paralelamente, la habilidad para sintetizar parches automáticamente. |
| ZeroDayBench                    | Inteligencia ofensiva no vista        | Evalúa si un agente simplemente está repitiendo exploits de sus datos de entrenamiento o si puede deducir la explotación sobre un día cero absoluto sin registros previos.                                  |

|                                   |                                          |                                                                                                                                                                                                                                                       |
|-----------------------------------|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>SANDBOXESCAPEBENCH</b>         | Escape de infraestructura                | Cuantifica la propensión y capacidad técnica de modelos fronterizos potentes para lograr evadir la contención de entornos Docker o máquinas virtuales aisladas.                                                                                       |
| <b>JailbreakBench / AgentHarm</b> | Resiliencia de Guardarrailes y Toxicidad | Proporcionan un análisis estandarizado de la efectividad de defensas estructurales contra ataques adversarios como los generados por <i>PyRIT</i> , midiendo paralelamente cuán destructivo podría ser un agente si se subvierte su política interna. |

## 8. Consideraciones Finales y Postura Estratégica

La taxonomía y el análisis extraído de este conjunto masivo de repositorios de código abierto confirman que la aplicación de la inteligencia artificial generativa en ciberseguridad ha superado la etapa experimental. Constituye un ecosistema operativo que requiere una profunda comprensión técnica para su asimilación empresarial. A partir de las herramientas desglosadas, se establecen las siguientes proyecciones y recomendaciones prioritarias para el despliegue sectorial:

### 1. Priorización de Arquitecturas sobre Modelos Genéricos:

El rendimiento superior no se obtiene licenciando un modelo LLM con más billones de parámetros, sino implementando arquitecturas especializadas de orquestación de enjambres o de "humano en el bucle" (como **Burp AI** y la asistencia contextual de **PentestGPT**). En escenarios de pruebas de penetración y SOC, la fragmentación de tareas complejas en sub-agentes asíncronos y la provisión de conexiones integradas al entorno físico son el único mecanismo comprobado para evadir la pérdida de contexto del modelo y vencer la brecha de rendimiento real.

### 2. Implantación Mandatoria del Escaneo de Modelos y el Mapeo de Cumplimiento:

El lanzamiento de aplicaciones impulsadas por modelos de IA exige controles formales de AppSec dedicados y nativos. Utilizar herramientas estáticas de TI es insuficiente. Se debe establecer una integración de Integración Continua / Despliegue Continuo (CI/CD) orquestada con herramientas como **promptfoo** y **Giskard**, las cuales no solo

automatizan las inyecciones adversarias y el fuzzing adaptativo para prevenir regresiones en cada actualización de los modelos, sino que consolidan automáticamente un rastro de auditoría de acuerdo con la estricta Ley de IA de la UE (EU AI Act) y las directrices del NIST.

### 3. **Defensa en Profundidad (Defense in Depth) en la Era de los Agentes:**

A medida que los agentes de IA desarrollan la capacidad de invocar funciones ejecutivas de alto nivel, la protección del modelo debe extenderse más allá de la capa semántica. Organizaciones serias deben establecer una tubería en tres frentes: el uso de cortafuegos de lenguaje como **LLM Guard** y **Llama Guard 3** para bloquear fugas de PII o inyecciones previas al procesamiento; la supervisión de señales internas e instrumentación como las métricas de palabras canario (canary words) de **Rebuff** para detectar la exfiltración subrepticia en tiempo real; y la contención absoluta de la topología del agente mediante microVMs declarativas tipo **OpenShell** u **OpenSandbox** para impedir la persistencia de adversarios en caso de compromiso total de la inferencia.

Al comprender las categorizaciones documentadas en *Awesome-AI-Cybersecurity*, *AI-for-Cybersecurity*, *Awesome-GPT-Agents* y *Awesome GenAI CyberHub*, los analistas pueden discernir qué proyectos ofrecen bases académicas probadas y qué marcos emergentes definirán el estándar de la industria en la consolidación de infraestructuras ciber-resilientes.

## **Obras citadas**

1. Ashfaaq98/awesome-genai-cyberhub: A curated list of AI ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/Ashfaaq98/awesome-genai-cyberhub>
2. Awesome AI for Security - Aman Priyanshu, fecha de acceso: abril 30, 2026, <https://amanpriyanshu.github.io/Awesome-AI-For-Security/>
3. Elniak/awesome-ai-cybersecurity: Welcome to the ultimate ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/Elniak/awesome-ai-cybersecurity>
4. Billy1900/Awesome-AI-for-cybersecurity: Awesome list of AI ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/Billy1900/Awesome-AI-for-cybersecurity>
5. The Rise of AI Pentesting Agents: A Technical Analysis (2026), fecha de acceso: abril 30, 2026, <https://appsecsanta.com/research/ai-pentesting-agents-2026>
6. Pentest GPT in 2026, From Clever Prompts to Verified Findings, fecha de acceso: abril 30, 2026, <https://www.penligent.ai/hackinglabs/he/pentest-gpt-in-2026-from-clever-prompts-to-verified-findings/>
7. Best AI-Powered Penetration Testing Tools for the 2026 Financial Year, fecha de acceso: abril 30, 2026, <https://www.thestreet.com/crypto/newsroom/best-ai-powered-penetration-testing-tools-2026>
8. GitHub - GreyDGL/PentestGPT: Automated Penetration Testing, fecha de acceso: abril 30, 2026, <https://github.com/greydgl/pentestgpt>



9. ipa-lab/hackingBuddyGPT: Helping Ethical Hackers use LLMs in 50, fecha de acceso: abril 30, 2026, <https://github.com/ipa-lab/hackingBuddyGPT>
10. Releases · ipa-lab/hackingBuddyGPT - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/ipa-lab/hackingBuddyGPT/releases>
11. frOgger/Awesome-GPT-Agents: A curated list of GPT agents ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/frOgger/Awesome-GPT-Agents>
12. ottosulin/awesome-ai-security: A collection of awesome ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/ottosulin/awesome-ai-security>
13. corca-ai/awesome-llm-security: A curation of awesome ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/corca-ai/awesome-llm-security>
14. Securing Your AI Agents Before They Ship: Red Teaming with, fecha de acceso: abril 30, 2026, <https://techcommunity.microsoft.com/blog/appsonazureblog/securing-your-ai-agents-before-they-ship-red-teaming-with-microsoft-pyrit/4515514>
15. Top Open Source AI Red-Teaming and Fuzzing Tools in 2025, fecha de acceso: abril 30, 2026, <https://www.promptfoo.dev/blog/top-5-open-source-ai-red-teaming-tools-2025/>
16. Pyrit: LLM-Orchestrated AI Red-Teaming & Adversarial Testing, fecha de acceso: abril 30, 2026, <https://mcpmarket.com/server/pyrit>
17. microsoft/PyRIT-Ship: Integrate PyRIT in existing tools - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/microsoft/PyRIT-Ship>
18. NVIDIA/garak: the LLM vulnerability scanner - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/NVIDIA/garak>
19. garak: LLM vulnerability scanner, fecha de acceso: abril 30, 2026, <https://garak.ai/>
20. Mastering LLM Security: A Deep Dive into Garak Vulnerability Scanner, fecha de acceso: abril 30, 2026, <https://medium.com/@kachwalla64/mastering-llm-security-a-deep-dive-into-garak-vulnerability-scanner-a1274003aa47>
21. Garak: Open-source LLM vulnerability scanner - Help Net Security, fecha de acceso: abril 30, 2026, <https://www.helpnetsecurity.com/2025/09/10/garak-open-source-llm-vulnerability-scanner/>
22. OpenAI Acquires Promptfoo, Gaining 25% Foothold in Fortune 500, fecha de acceso: abril 30, 2026, <https://futurumgroup.com/insights/openai-acquires-promptfoo-gaining-25-foothold-in-fortune-500-enterprises/>
23. AI Security: Promptfoo, Strix, CAI, and Giskard (Updated), fecha de acceso: abril 30, 2026, <https://blog.ogwilliam.com/post/giskard-promptfoo-strix-cai-ai-security-benchmark>
24. meta-llama/PurpleLlama: Set of tools to assess and improve LLM, fecha de acceso: abril 30, 2026, <https://github.com/meta-llama/PurpleLlama>
25. Issues · meta-llama/PurpleLlama - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/meta-llama/PurpleLlama/issues>



26. Labels · meta-llama/PurpleLlama - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/meta-llama/PurpleLlama/labels/Llama-Guard>
27. protectai/llm-guard: The Security Toolkit for LLM Interactions - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/protectai/llm-guard>
28. Protect AI - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/protectai>
29. 10 LLM Security Tools to Know in 2025 - Pynt, fecha de acceso: abril 30, 2026, <https://www.pynt.io/learning-hub/llm-security/10-llm-security-tools-to-know>
30. A Review of TRiSM Frameworks in Artificial Intelligence Systems, fecha de acceso: abril 30, 2026, <https://www.techrxiv.org/doi/pdf/10.36227/techrxiv.174913612.20443736>
31. protectai/rebuff: LLM Prompt Injection Detector - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/protectai/rebuff>
32. Issues · protectai/rebuff - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/protectai/rebuff/issues>
33. An Empirical Analysis of LLM-Powered Applications and Local, fecha de acceso: abril 30, 2026, [https://bozhen-liu.github.io/assets/pdf/LPA\\_Alware25-preprint.pdf](https://bozhen-liu.github.io/assets/pdf/LPA_Alware25-preprint.pdf)
34. jivoi/awesome-ml-for-cybersecurity: Machine Learning for ... - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/jivoi/awesome-ml-for-cybersecurity>
35. Best GitHub Security Tools for Secure Repositories, fecha de acceso: abril 30, 2026, <https://www.aikido.dev/blog/top-github-security-tools>
36. Where to find reliable annotated cybersecurity datasets for Machine, fecha de acceso: abril 30, 2026, [https://www.researchgate.net/post/Where\\_to\\_find\\_reliable\\_annotated\\_cybersecurity\\_datasets\\_for\\_Machine\\_Learning](https://www.researchgate.net/post/Where_to_find_reliable_annotated_cybersecurity_datasets_for_Machine_Learning)
37. beyefendi/awesome-llm-security - GitHub, fecha de acceso: abril 30, 2026, <https://github.com/beyefendi/awesome-llm-security>